Awal Global Consults Limited

GAP ASSESSMENT REPORT

Cybersecurity and Data Protection Gap Assessment

Current-state maturity of Example Foods Ltd measured against the NIST Cybersecurity Framework 2.0, with NDPA 2023 obligations, target maturity and a prioritised 90-day roadmap.

Client	**Example Foods Ltd (a fictional company, used for illustration only)**
Framework	**NIST CSF 2.0 (22 categories), NDPA 2023**
Assessor	**A.O. Abdullateef, Awal Global Consults Limited (RC-9282103)**
Version	**1.0, 3 November 2026**
Classification	**Confidential (sample)**

Illustrative sample. Example Foods Ltd is a fictional company. This document shows the method, structure and quality of a real engagement; it is not a client deliverable and contains no client information. Prepared by A.O. Abdullateef, Awal Global Consults Limited (RC-9282103).

1. Executive summary

Example Foods Ltd has grown quickly on WhatsApp, email and online payments, but its security and data protection practices have not kept pace. Across the 22 NIST CSF 2.0 categories the business scores an average maturity of **0.8 out of 5** against an agreed target of **2.9**. The weakest areas are governance (no policies or named owner) and incident response (no plan and no awareness of the 72-hour breach notification duty under the NDPA).

0.8	2.9	8	19
Average current maturity (0–5)	Average target maturity	Priority 1 gaps (act in 30 days)	Categories two or more levels below target

Most urgent gaps

- **GV.RM Risk Management Strategy:** No risk appetite or method; risks handled when they occur.
- **GV.RR Roles, Responsibilities, and Authorities:** No named owner for information security or data protection.
- **GV.PO Policy:** No information security, acceptable use or data protection policy.
- **ID.AM Asset Management:** No list of devices, accounts, systems or where personal data is held.
- **PR.AA Identity Management, Authentication, and Access Control:** Shared email password; no two-step verification; former staff still on WhatsApp and bank logins.
- **PR.AT Awareness and Training:** No staff training; finance staff unaware of invoice fraud patterns.

> **Headline recommendation:** name a security and data protection lead, protect the WhatsApp, email and payment processes this week, and approve a short policy set and breach response plan within 30 days. Most actions cost staff time rather than new software.

2. Scope and approach

Organisation: A Lagos food manufacturer and distributor with 40 staff, two sites (Ikeja office and an Agbara factory), about 3,000 retail and wholesale customers, orders taken on WhatsApp Business and a website, payments by bank transfer and an online payment gateway, NAFDAC-registered products, and customer and staff personal data held in spreadsheets, a cloud accounting system and shared email.

Scope: Information security and data protection across the head office, factory office, sales and finance teams; business email, WhatsApp Business, website, payment processes, laptops and phones; personal data of customers and staff. Out of scope: factory production control systems.

Method

1. **Scope and context:** kick-off with the Managing Director; agree scope, obligations and target profile.
2. **Evidence gathering:** interviews with the MD, Finance, Sales and HR leads; walkthrough of account settings, payment approvals and device configuration; review of existing documents.

3. **Scoring:** each NIST CSF 2.0 category scored 0–5 for current and target maturity, using the scale below. Scores reflect evidence seen, not intentions.
4. **Gap analysis:** gap = target minus current; each gap given a priority by its link to the top risks in the risk register.
5. **Roadmap:** recommendations grouped into a 90-day plan with owners, then validated with management.

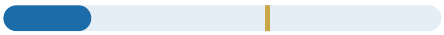
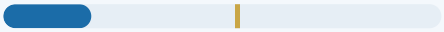
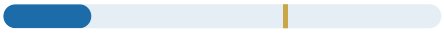
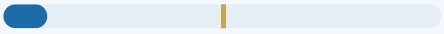
Maturity scale

Level	Name	Meaning
0	None	No practice in place
1	Initial	Ad hoc, depends on individuals
2	Repeatable	Done consistently but not documented
3	Defined	Documented, approved and communicated
4	Managed	Measured and reviewed regularly
5	Optimised	Continuously improved from results

Priorities: P1 act within 30 days, linked to a High or Critical risk; P2 within 60 days; P3 within 90 days.

3. Results by function

Blue bar: current maturity. Gold marker: target. Govern is new in CSF 2.0 and sits at the centre of the framework: it covers strategy, roles, policy and supplier risk.

Function	Categories	Current	Target	Profile (0–5)	Gap
Govern	6	1.0	3.0		2.0
Identify	3	1.0	2.7		1.7
Protect	5	1.0	3.2		2.2
Detect	2	0.5	2.5		2.0
Respond	4	0.2	2.8		2.5
Recover	2	0.5	2.5		2.0

4. Detailed findings

Govern

ID	Category	Now	Target	Finding	Recommendation	Priority
GV.OC	Organizational Context	2	3	Owners understand obligations informally (NAFDAC, NDPA, tax) but they are not written down.	Record legal, regulatory and contractual security obligations in one register.	P2
GV.RM	Risk Management Strategy	1	3	No risk appetite or method; risks handled when they occur.	Adopt the risk method and appetite statement in this report; review the register quarterly.	P1
GV.RR	Roles, Responsibilities, and Authorities	1	3	No named owner for information security or data protection.	Name a security and data protection lead with board reporting.	P1
GV.PO	Policy	0	3	No information security, acceptable use or data protection policy.	Approve an information security policy set and staff acknowledgement.	P1
GV.OV	Oversight	1	3	Board receives no security reporting.	Quarterly one-page security and privacy report to the board.	P3
GV.SC	Cybersecurity Supply Chain Risk Management	1	3	Payment gateway, cloud accounting and IT vendor chosen without security checks.	Supplier security questionnaire and contract clauses for key vendors.	P2

Identify

ID	Category	Now	Target	Finding	Recommendation	Priority
ID.AM	Asset Management	1	3	No list of devices, accounts, systems or where personal data is held.	Asset and data inventory, including who holds each account.	P1
ID.RA	Risk Assessment	1	3	No assessment before this engagement.	Maintain the attached risk register; reassess after changes.	P2
ID.IM	Improvement	1	2	Incidents (one hijacked WhatsApp account last year) not reviewed for lessons.	Short post-incident review for every incident.	P3

Protect

ID	Category	Now	Target	Finding	Recommendation	Priority
PR.AA	Identity Management, Authentication, and Access Control	1	4	Shared email password; no two-step verification; former staff still on WhatsApp and bank logins.	Individual accounts, two-step verification everywhere, leaver process the same day.	P1
PR.AT	Awareness and Training	0	3	No staff training; finance staff unaware of invoice fraud patterns.	Annual training plus induction briefing; phishing examples for finance.	P1
PR.DS	Data Security	1	3	Customer lists in spreadsheets emailed around; no encryption on laptops.	Restrict customer data to one system, encrypt laptops, stop emailing exports.	P2
PR.PS	Platform Security	2	3	Some laptops a year behind on updates; no endpoint protection on two.	Automatic updates and endpoint protection on all devices.	P2
PR.IR	Technology Infrastructure Resilience	1	3	Single internet link; office Wi-Fi uses default password and is shared with visitors.	Separate guest Wi-Fi, change defaults, backup mobile data link for sales.	P3

Detect

ID	Category	Now	Target	Finding	Recommendation	Priority
DE.CM	Continuous Monitoring	1	3	Bank alerts only on one account; no login alerts on email or social media.	Turn on bank, email and social login alerts; weekly review by the lead.	P2

ID	Category	Now	Target	Finding	Recommendation	Priority
DE.AE	Adverse Event Analysis	0	2	No way for staff to report suspicious messages.	Single reporting channel and simple triage checklist.	P3

Respond

ID	Category	Now	Target	Finding	Recommendation	Priority
RS.MA	Incident Management	0	3	No incident response plan.	Incident and data breach response plan with contacts and decision tree.	P1
RS.AN	Incident Analysis	0	2	Incidents not investigated or recorded.	Incident log with cause, impact and evidence kept.	P3
RS.CO	Incident Response Reporting and Communication	0	3	Unaware of the NDPA 72-hour notification duty.	Notification templates for the NDPC, customers and the bank.	P1
RS.MI	Incident Mitigation	1	3	Containment steps (password resets, revoking sessions, calling the bank) not defined.	Containment checklist inside the response plan.	P2

Recover

ID	Category	Now	Target	Finding	Recommendation	Priority
RC.RP	Incident Recovery Plan Execution	1	3	Accounting data backed up by vendor; other files not backed up; restore never tested.	Automatic backup of shared files; test a restore every six months.	P2
RC.CO	Incident Recovery Communication	0	2	No plan for telling customers after an incident.	Customer communication templates and approval route.	P3

5. NDPA 2023 observations

Obligation	Observation	Status
Lawful basis and privacy notice	No privacy notice on the website or WhatsApp catalogue; marketing messages sent without recorded consent.	Gap
Security of processing	Shared passwords and unencrypted laptops do not meet the duty to apply appropriate technical and organisational measures.	Gap
Breach notification (72 hours to the NDPC)	Duty not known; no plan or templates.	Gap
Data subject rights	No process for access, correction or deletion requests.	Gap
Data processors	Cloud accounting and payment providers used without data processing terms.	Gap
Registration and annual compliance returns	Data-subject volumes not tracked, so registration status as a data controller of major importance is unknown.	Review

6. 90-day roadmap

When	Theme	Actions
Week 1	Protect accounts and payments	WhatsApp PIN and recovery, call-back rule for bank-detail changes, second approval for large payments, staff warning on code scams.
Month 1	Own the programme	Name a security and data protection lead, approve the policy set, leaver process, two-step verification on all accounts, breach response plan.
Month 2	Harden and back up	Encrypt laptops, automatic updates and endpoint protection, backups with a tested restore, stop emailing customer exports, staff training.
Month 3	Suppliers and oversight	Supplier questionnaires and contract clauses, NDPC registration check, first quarterly board report, reassess the risk register.

Success measures at day 90: no shared accounts; two-step verification on 100% of business accounts; policy acknowledgement from every staff member; one tested backup restore; breach plan approved and walked through; average maturity raised to at least 1.8.

7. Management response and sign-off

Role	Name	Signature	Date
Managing Director (risk owner)			
Security and data protection lead			
Assessor	A.O. Abdullateef		

Limitations: this assessment relied on interviews, walkthroughs and documents provided at the time. It did not include technical testing such as penetration testing or vulnerability scanning. Companion documents: risk assessment and register; information security policy.